

Apprenticeship Additional Knowledge Unit

Lesson 2





Study Information and Tips



This Study Text replicates the video content for the lesson



Supplementary knowledge can also be found in the information sheets and text boxes that accompany the videos, as well as in the resources in the Insights section



Activities to help you consolidate your knowledge are deliberately delivered through practice questions and exercises found in the Test and Apply sections on the VLE. These help you to further build on your knowledge and apply the learning in a way that supports your assessment



You can use this Study Text to test your understanding of the learning content at the end of each lesson. It may also be helpful to refer to it when preparing for your assessments



We recommend that you also produce your own notes in addition to the Study Text. Research has shown that handwritten notes can be very effective for learning retention



If you decide to print this Study Text, set the layout to print 4 or 6 slides per page to save on paper and ink



Organisational Governance, Legislation and Regulation

**Role of governance
in decision-making
and long-term
sustainability**

**How legislation and
regulation inform
proper operations
and conduct**

**Compliance as
internal controls
for adhering to
obligations and
minimising risks**

**Key laws and
regulations – data
protection, health and
safety, and equality
and diversity**



What is Organisational Governance?

The main purpose of any company is to reach its goals and succeed in the long term. To facilitate this, there must be systems in place to ensure that managers are held to account and that decisions are made in the best interests of the organisation.

Most organisations have a system in place to guide their direction, and ensure that procedures are aligned with their goals and wider responsibilities.

This system, known as 'organisational governance', supervises management processes and operations within the business.





Role of Governance

The International Organization for Standardization's 'social responsibility' standard (ISO 26000) defines organisational governance as “a system by which an organisation makes and implements decisions in pursuit of its objectives”.

The purpose of governance is to try to ensure the long-term sustainability of a business through effective decision-making.

Organisational governance – also known as ‘corporate governance’ – involves putting in place specific frameworks and management processes to both deliver performance objectives, and handle the interests of stakeholders.

These practices are designed to control and direct business activities through policies that set out how the organisation – and the people within it – should operate.



Adherence to Legal Responsibilities

One important role of governance is managing an organisation's legal responsibilities, and ensuring that applicable legislation and regulation is adhered to.

The distinction between the terms 'legislation' and 'regulation' is not universally defined. But in the UK it's generally accepted that 'legislation' refers to laws, statutes, or Acts that have derived from parliament.

Meanwhile, regulations are rules enforced by government agencies, and set the standards for what can and cannot be done in business.

Organisational governance is necessary for setting the direction of, and monitoring, compliance with these laws and rules, so that an organisation avoids the penalties of not conforming. These include fines, legal action and any associated reputational damage.



Legislation and Regulation for Organisations

The UK has legislation and regulation that applies across all businesses – irrespective of size, sector or the products or services produced.

For example, the Health and Safety at Work etc. Act 1974 and Equality Act 2010 are laws that aim to protect people in all types of workplaces and wider society.

And the General Data Protection Regulation is a legal framework that sets guidelines for the collection and processing of personal information.

Public and privately run organisations in the UK must also be set up and managed in line with the Companies Act 2006. This legislation governs areas such as operations and financing.





Corporate Governance Code

Some UK organisations must also adhere to the 'Corporate Governance Code'. This framework sets out a number of recommendations for how boards should oversee the management of an organisation. For instance, guidance on who sits on the board and their responsibilities, and directions on remuneration.

The Code also looks at how organisations manage their approach to audit, risk and internal control. Part of this aims to ensure that a company's processes present a fair, balanced, and understandable assessment of its position and prospects.

Other aspects include meeting further legislative and regulatory requirements, and maintaining ethical practices.

Business-specific Legislation and Regulations

Specific legislation and regulations to follow vary, depending on business type and sector.

For example, restaurants, cafés and others in the food production supply chain must abide by the Food Safety Act 1990, and the Food Standards Act 1999. Meanwhile, travel agents and tour operators are governed by different regulations, such as the EU 'Package Travel Directive', and 'Air Traffic Organisers Licensing' (ATOL) protection.



Principles of Organisational Governance

So, legislation and regulation contribute to the necessary framework for effective organisational governance and, in return, organisational governance aims to ensure that these laws and rules are followed in practice.

You can find out more by downloading this lesson's 'Principles of Organisational Governance' information sheet.





What is Compliance?

Because all UK companies must abide by certain laws and regulations, organisational governance should include having policies, practices, processes and procedures in place to ensure compliance.

‘Compliance’ can be defined as “the act of obeying a law or rule, especially one that controls a particular industry or type of work”. It usually involves having a system of internal controls to ensure that organisational policies and procedures are followed, and that they align with statutory obligations.

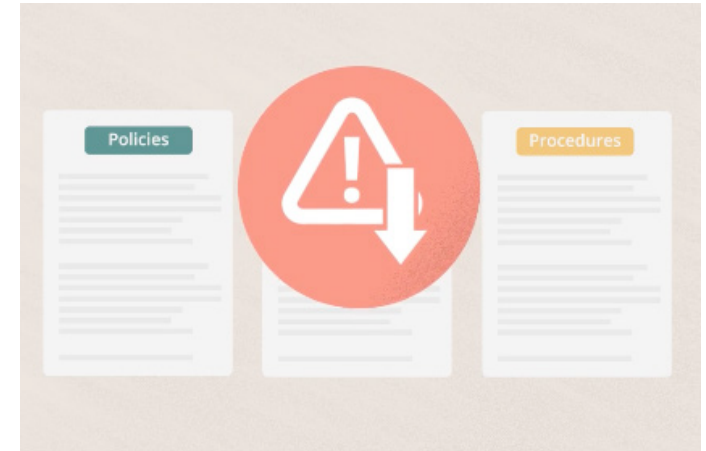


Preventative and Detective Controls

In practice, compliance is often arranged into two key areas – ‘preventative internal controls’ and ‘detective internal controls’.

Preventative controls are measures to catch any errors before they occur. For example, protocols for authorising spending approval when making significant financial transactions.

By contrast, detective controls find existing issues in protocols and processes. The aim is to identify and correct any weaknesses before an organisation risks being penalised – or to highlight where problems may worsen if left unaddressed.



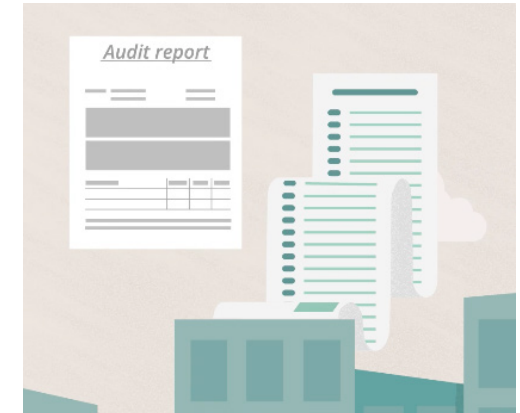


Audits

An example of a detective control would be an organisation carrying out regular checks – or audits – on company spending, to ensure that managers are following the agreed approval protocols. In this way, detective controls also minimise the potential for non-compliance.

To ensure compliance, an organisation may also undertake audits like these to determine whether its activities meet applicable legal requirements, as well as internal controls and policies.

Audits can check compliance in a range of different areas. For instance, a 'pay audit' might help to spot any salary discrepancies among groups of employees, or check that wages meet statutory minimum requirements.



ID	Name	Code	Wage
number	string	number	number
1	G Young	10135723	
2	D Barlow	33952406	
3	J Cohen	67367735	
4	M Singh	45575529	
5	T Bwak	1027823	
6	T Adams	35477723	
7	C Mason	33954487	
8	P Wang	47548543	
9	E Griffin	88565356	



Financial Statement Audits

One of the most common types of compliance auditing relates to a company's financial management. These audits are generally used to analyse the fairness and accuracy of the business's financial statements, for stakeholder reporting purposes.

According to the UK's 'Corporate Governance Code', one of the main roles of auditing to manage finances is "monitoring the integrity of financial statements, and any formal announcements relating to the company's financial performance". And "reviewing significant financial reporting judgements contained in them".

Audit reporting can help to identify the strength of compliance preparations, and look for weaknesses in existing policies or practices. It may also provide suggestions for improved risk management procedures, or make recommendations for resolving potential issues.



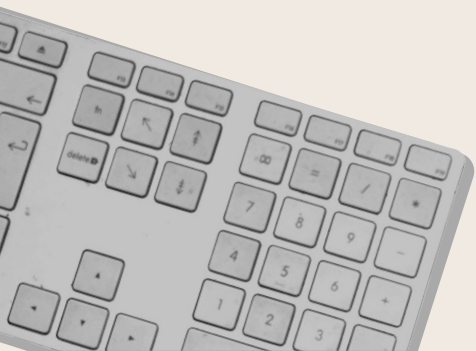


Contingency Planning

Although organisational governance and compliance are two separate practices, in reality, they are closely linked. They both serve the purpose of seeking to limit the risks involved in running a business, with a view to ensuring its long-term sustainability.

But what can organisations actually do to respond if an incident does occur, or if they fall short with their governance and compliance?

Read this lesson's 'Business Continuity and Contingency Planning' information sheet to find out more about how contingency plans can help with this process.



Legislation for Managers

Different types of legislation that an organisation must adhere to include laws that impact distinct aspects of running a business, such as protecting employees, consumer rights and legal ownership of new ideas.

It's important for managers to be aware of the legislation and regulation that informs their business sector and organisation so that they can ensure they – and their team members – are acting compliantly.



Bribery and Intellectual Property

The Bribery Act 2010 makes it illegal for representatives of an organisation to try to influence a decision maker by offering a bribe, promise or reward – particularly if this is part of a tender process.

Intellectual property (IP) law can protect organisations from having the names of its products, brands or inventions stolen or copied. It can also help to define ownership of 'creations of the mind'. In the UK, IP law incorporates a number of legislative acts, such as the Copyright, Designs and Patents Act 1988 and the Intellectual Property Act 2014.



Consumers and Working Time

Consumer law aims to protect consumers from unfair business practices and poor-quality products, as well as fraudulent representation or mis-selling. For instance, the Consumer Rights Act 2015 consolidates a number of different laws into a single framework protecting consumer rights.

The Working Time Regulations 1998 (WTR) protects workers' rights by setting rules about the maximum weekly working hours and minimum rest times, as well as ensuring holiday entitlements that staff must receive in the interest of their health, safety and wellbeing.





Data Protection Legislation

Another area of legislation that is particularly important for managers is data protection law. Managers need to have a good understanding to ensure that the personal data of fellow employees, customers, service users and other third parties is protected.

Without such legislation in place, people's personal information could be vulnerable to a range of threats, including privacy breaches, identity theft and fraud.

Let's look at key elements of data protection legislation, including the General Data Protection Regulation.





Personal Data

Data protection legislation ensures that any personal data that organisations collect is processed and stored properly.

Personal data is information that can be used to identify a living individual – directly or indirectly. In addition, some categories of personal data are considered to be particularly sensitive.

For instance, details of racial or ethnic origin, political opinions, religious beliefs, sexual orientation, and health.



Identifiers

People can be identified by one or more pieces of data. Take the example of a customer called 'John Smith'. Because it's a popular name, this information alone may not be enough to identify one individual.

However, combining 'John Smith' with another detail, such as date of birth, makes finding a specific customer more likely.

Such identifiers may also include things like someone's physical address, online location, National Insurance number, or bank details.





General Data Protection Regulation (GDPR)

The growth in internet use – and associated technology like social media and ‘cloud’ storage – has led to the need for increased protection of, and control over, personal data.

To address this, the European Union created the General Data Protection Regulation (GDPR) which came into effect in May 2018.



UK GDPR

Even though the UK left the EU in 2020, GDPR still applies in the form of the 'UK GDPR', which includes minor changes to make it work more effectively in a UK context.

The UK GDPR was designed to sit alongside the Data Protection Act 2018. This Act also contributes UK-specific detail – including enforcement of data protection in the UK, and exemptions from obligations in certain situations.

And, it sets out the role of the Information Commissioner's Office – or 'ICO' – the UK's regulatory body for data protection and information rights.



GDPR Principles

GDPR governs how organisations collect, process, and protect people's personal data. It has several principles that organisations must follow.

These include ensuring that personal data is collected and processed lawfully, transparently, and for a specific purpose.

Companies must also ensure that the personal data they collect is accurate, up to date, and only held for as long as it's needed.

In addition, they should take measures to keep data secure. An organisation also has to tell an individual what personal data it holds on them if they request it.



Data Protection Officer (DPO)

To ensure compliance with the GDPR, organisations may appoint a 'data protection officer' (DPO). This person should be independent, an expert in data protection, and report to senior management.

It's mandatory for some organisations to appoint a DPO. Examples of these include public authorities or bodies, as well as companies that conduct certain types of data processing activities. Others may choose to appoint a DPO voluntarily.



DPO's Responsibilities

DPOs are responsible for overseeing a company's data protection policies, strategies and procedures.

These policies outline an organisation's approach to data protection, including the principles, responsibilities, and practices that must be followed for the organisation to be compliant.

DPOs also monitor how closely data protection legislation is being followed, and offer guidance to the company and employees.





DPO's Responsibilities (cont.)

As well as being the authority on data protection within an organisation, DPOs serve as a point of contact for 'data subjects'. These are the individuals whose data an organisation processes.

The DPO is also the organisation's contact point for the Information Commissioner's Office.

Through roles like the DPO, we can start to see the many implications of personal data protection brought about by GDPR legislation.



Data Controller and Data Processor

The GDPR distinguishes between two 'roles' involved in the collection, storage and processing of personal data – 'data controller' and 'data processor'. Depending on the circumstances, these roles may relate to organisations or individuals.

A data controller is the organisation or individual that makes decisions about why, how and what personal data is collected, used, and processed. For example, an online shopping company might be a data controller.

A data processor, on the other hand, is the organisation or individual that handles personal data and translates it into usable information on behalf of the data controller.

For instance, if the online shopping company uses a cloud service provider to store and handle its customer data, the cloud service provider would be a data processor. They don't make decisions about why or how data is processed, they follow the instructions of the data controller.





Data Protection Principles

We've seen that several key principles of data protection form the backbone of the GDPR (currently retained in domestic law as UK GDPR).

You can read about these principles, as well as their implications for data processing and individuals' rights, in this lesson's 'Seven Principles of Data Protection and Individuals' Rights' information sheet.



Health and Safety Legislation

Let's continue to look at legislation and regulation that governs organisations. This time with regard to ensuring personal safety and wellbeing.

Health and safety is one of the most important – and sometimes most overlooked – aspects of working life. According to the Health and Safety Executive, 1.7 million working people suffered from work-related ill health between 2023 and 2024. In the same period, 33.7 million working days were lost due to work-related illness and workplace injury.

It's vital that organisations take measures to prevent workplace accidents, injuries, and illnesses. There is a range of UK health and safety legislation that's designed to protect individuals and support organisations.





Health and Safety at Work etc. Act 1974

The Health and Safety at Work etc. Act 1974 (HSWA) is the primary piece of legislation covering occupational health and safety in Great Britain.

The Act sets out general health and safety duties that:

- Employers have towards employees and members of the public
- Employees have to themselves and each other
- Self-employed people have towards themselves and others



The Management of Health and Safety at Work Regulations 1999

However, while the Act sets out an overarching legal framework and general duties, it doesn't specify exactly what each party needs to do in practice.

So it's supplemented by a variety of regulations and codes of practice. One of the most important of these for workplaces, is The Management of Health and Safety at Work Regulations 1999 (MHSWR).

MHSWR sets out important health and safety requirements for employers and employees. It gives practical guidance on how everyone should manage health and safety at work. Let's look at some of these requirements.



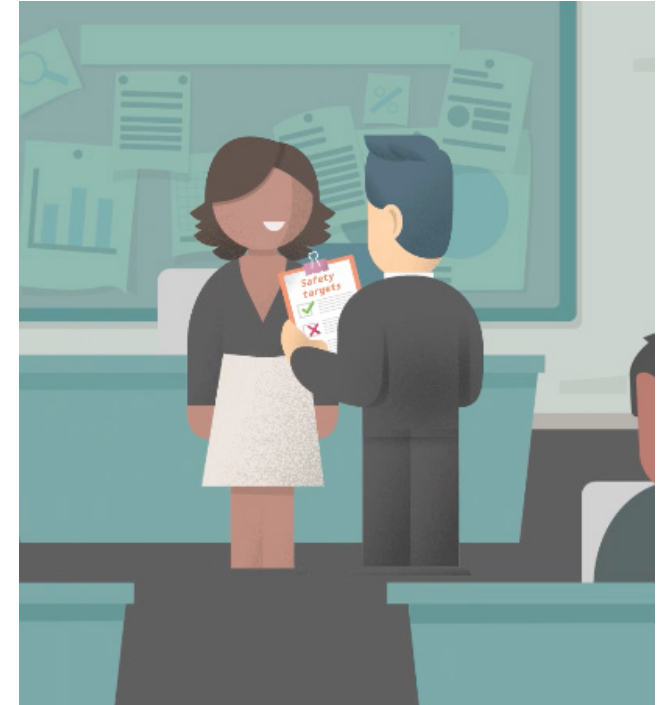
Appoint a 'Competent' Person

An organisation should appoint a 'competent' person to oversee and manage health and safety. This might be a dedicated health and safety manager, or a trained member of staff.

Their job is to handle all aspects of health and safety, ensure compliance with legislation, and give advice and guidance to employees.

Part of this role includes assessing and controlling health and safety risks. Organisations must carry out risk assessments to identify and evaluate hazards like slippery floors, or faulty electrical equipment.

They must then put in place measures to manage the risks. In these cases, perhaps implementing signage or replacing old hardware.





Establish Emergency Procedures

Companies must also establish emergency procedures to follow in case of accidents or potentially dangerous situations.

These might include how to report an incident, contact emergency services, evacuate the workplace, or give first aid.



Maintain Records of Incidents and Actions

Another key requirement is maintaining records of health and safety incidents and the actions taken to address them.

This is vital to demonstrate compliance with the legislation. It also helps identify areas for improvement, and then put remedies in place so that future incidents are avoided or minimised.



Provide Information and Training

For all of this to work, employees need to be given information and training on health and safety.

This should inform them about the risks associated with their work and working environment – and how they can help manage them.

It could also provide guidance on how to operate equipment and machinery safely – and what to do in case of accidents or emergencies.



Employees' MHSWR Responsibilities

In turn, employees have their own responsibilities under the MHSWR.

They must ensure they use any equipment, operate safety devices, or handle dangerous substances as directed in the training or instruction they've received.

Employees must also notify their employer – or a designated health and safety representative – about any situation that presents an immediate danger to health and safety. And, whether there are any shortcomings in the employer's health and safety provision.

As you can see, together, these two pieces of legislation provide an overview of the employer's – and the employee's – responsibilities when it comes to managing health and safety.

Health and Safety Executive (HSE)

The Health and Safety Executive (HSE) is Britain's national regulator for workplace health and safety. Its role is to prevent work-related injury and ill health by ensuring that organisations follow and comply with health and safety legislation.

This involves setting and enforcing standards, providing advice and guidance to employers, conducting research, collaborating with stakeholders, and taking legal action when necessary.

While its key focus is worker safety, its remit extends to the general public – to ensure that “people feel safe where they live, where they work and in their environment”.





Consequences of Non-adherence

It is important for those in a management role to be familiar with both HSWA and MHSWR. The implications of organisations failing to comply with these laws can be profound.

Find out more about this by downloading the 'Consequences of Not Adhering to Health and Safety Legislation' information sheet from the Learn section.





Display Screen Equipment Regulations

There are also other more specific pieces of legislation that supplement and complement the Act and regulations.

Download this lesson's associated information sheet to learn about a key set of regulations related to 'display screen equipment'.





RIDDOR

The Reporting of Injuries, Diseases and Dangerous Occurrences Regulations 2013 (RIDDOR) is a key piece of legislation under the Health and Safety at Work etc. Act 1974.

It requires companies to report certain health and safety events to the HSE. This allows authorities to work out how and where risks might arise, and whether they should be investigated. These events fall into three categories:

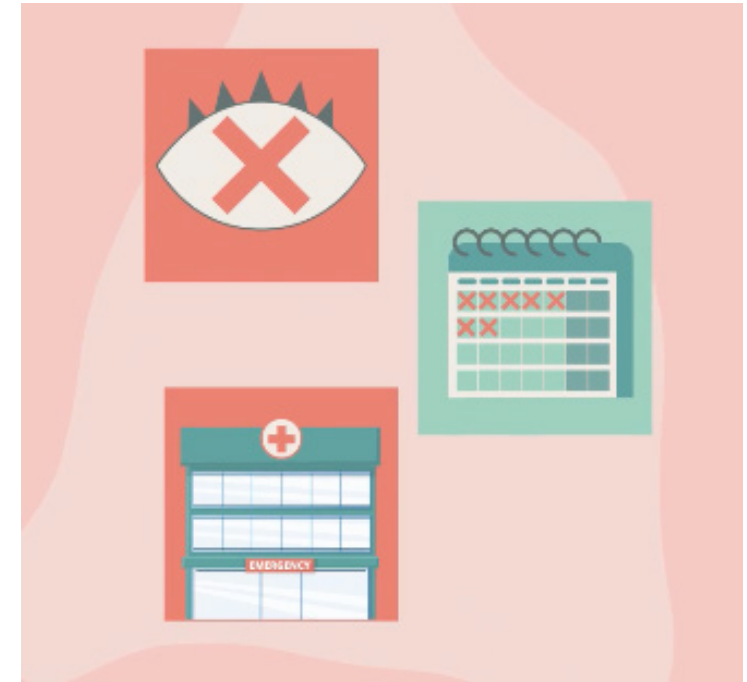
- Specified work-related injuries
- Occupational diseases
- Dangerous incidents



Work-related Injuries

A work-related injury must be reported if it results in death, or is one of the 'specified injuries' listed in the regulations. For example, an accident that may lead to someone losing their sight.

Injuries that last more than seven days and prevent employees from working must also be reported. Along with any accidents that happen to a member of the public that result in hospital treatment.





Occupational Diseases

Occupational diseases are diseases that are likely to be caused or made worse by work. For instance, occupational asthma.



Dangerous Incidents

Dangerous incidents are defined by the HSE as “certain, specified near-miss events” that have a high potential to cause death or serious injury, but which don’t happen very often.

This category includes things like equipment coming into contact with overhead power lines, or the accidental release of dangerous substances.





Reporting and Recording Requirements

Companies can report RIDDOR incidents through the HSE website.

They must also record reported occurrences. However, it's worth noting that there are some incidents which don't have to be reported, but do need to be recorded.

For example, organisations would record an injury that resulted in a worker being away for more than three consecutive days. But they wouldn't need to report it.

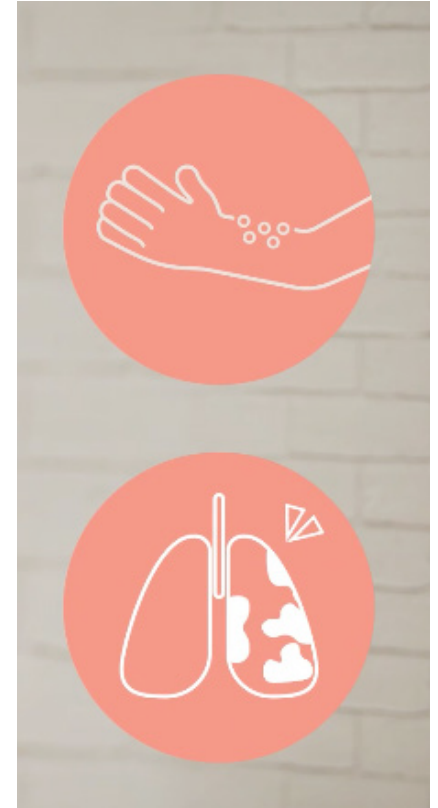
RIDDOR records should be kept up to date, strictly confidential and stored securely – whether that's in an accident log book or on a computer.



COSHH

Another key piece of workplace legislation is The Control of Substances Hazardous to Health Regulations 2002 (COSHH). COSHH requires employers to identify and control exposure to dangerous substances in the workplace.

This includes chemicals, fumes or dust that individuals might breathe in, or liquids and powders that cause irritation to the skin or eyes. Hazardous substances can have an immediate effect – for example, a rash. Or, take months or years to develop, such as with lung disease.





Employers' COSHH Duties

Under COSHH, organisations have a duty to:

- Identify hazards and carry out risk assessments
- Put controls in place to minimise risk
- Make sure these controls are used and maintained
- Ensure employees are fully trained
- Monitor any health risks
- Plan for potential emergencies



Health and Safety Legislation and Mental Health

Often when we think about health and safety, we think of its physical aspects. However, it's important to note that the legislation we've discussed also covers mental health.

You can find out more about how legislation deals with mental health by downloading this lesson's associated information sheet.



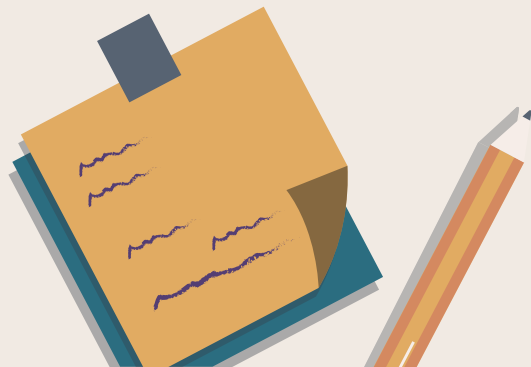


Equality Legislation

Let's continue to look at legislation that aims to protect people at work as well as in wider society, this time in relation to equal opportunity.

In the UK, everyone has the right to equal opportunity – fair and equitable treatment under the law. In the workplace, this means that all workers must be given the same level of respect, regardless of personal characteristics such as age, sex or race.

The opposite of equal treatment is discrimination, which is treating some people less – or more – favourably than others based on personal characteristics. This is illegal in the UK.





Equality Act 2010

The most important piece of UK legislation relating to equality, diversity and inclusion is the Equality Act 2010. It brings together over a hundred separate pieces of legislation into one single Act, to make them easier to apply.

The Equality Act serves to protect people from unfair treatment, and advance equality of opportunity for all – so that every person can make the most of their life and talents.

It plays a vital role by establishing clear legal standards. The Act empowers individuals to challenge discrimination, and creates a framework for promoting fairness and respect in organisations and wider society



Protected Characteristics

One of the key aims of the Act is to protect people from discrimination, harassment, and victimisation, based on certain personal characteristics. The Act calls these 'protected characteristics' and there are nine of them:

- race, including colour, ethnicity and nationality
- age
- disability
- sex
- sexual orientation
- gender reassignment
- marriage and civil partnership
- pregnancy and maternity
- religion or belief

Under the law, organisations must make sure that they do not discriminate either directly or indirectly against any employee on the basis of these characteristics.



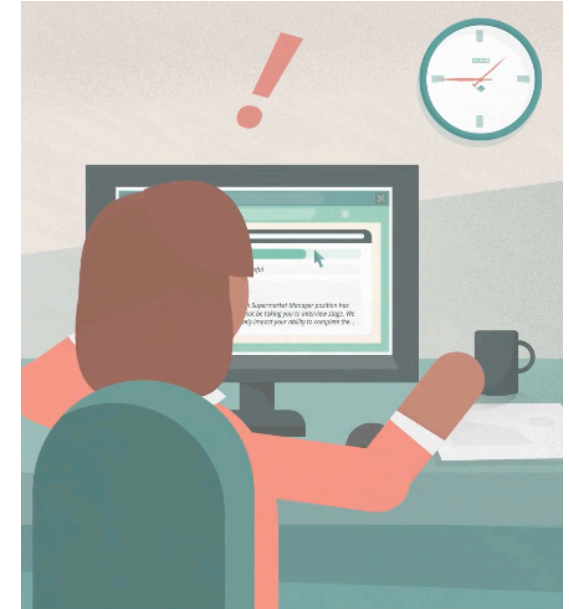
Direct Discrimination

‘Direct discrimination’ occurs when a person experiences unfair treatment because of a protected characteristic.

For example, let’s say a candidate with multiple sclerosis has applied for a job working in a supermarket. The hiring manager tells her that she won’t be given an interview because of her disability.

This is likely to be viewed as direct discrimination because multiple sclerosis is seen as a disability under the Equality Act, and it wouldn’t prevent the applicant from carrying out her duties.

Although there are situations in which a disability can make it impossible to perform a role, for many jobs this isn’t the case. And, employers are required to make ‘reasonable adjustments’ for otherwise qualified candidates.





Indirect Discrimination

‘Indirect discrimination’ occurs when the rules or arrangements that apply to all workers have a disproportionately negative impact on someone with a protected characteristic.

For instance, a requirement for job applicants to have a driving licence, when it isn’t really necessary for the role. This could indirectly discriminate against individuals with disabilities. For example, if a person isn’t allowed to drive because of a neurological condition.





Grounds for Discrimination

Note that it's not necessary for a person to actually have the protected characteristic for discrimination to take place. The employer only needs to believe it applies when they make decisions based on it.

Therefore, if an employer thinks that a member of staff has a disability, and denies them a promotion because of this, it could still amount to direct discrimination under the Equality Act – regardless of whether or not the person actually has a disability.



Harassment and Victimisation

While all types of workplace discrimination are covered under the Equality Act 2010, the law singles out a few discriminatory behaviours specifically.

Two of these – harassment and victimisation – are a threat to equality as well as being prohibited under the law. They are also interrelated.





Harassment

The Equality Act 2010 defines harassment as, “unwanted conduct related to a relevant protected characteristic” or “of a sexual nature” that “has the purpose or effect of violating [a person’s] dignity, or creating an intimidating, hostile, degrading or offensive environment”.

The Equality Act covers harassment based on most of the nine protected characteristics. The exceptions are being pregnant or on maternity leave, and being married or in a civil partnership. However, harassment relating to these attributes may sometimes be covered under the sex or sexual orientation categories.

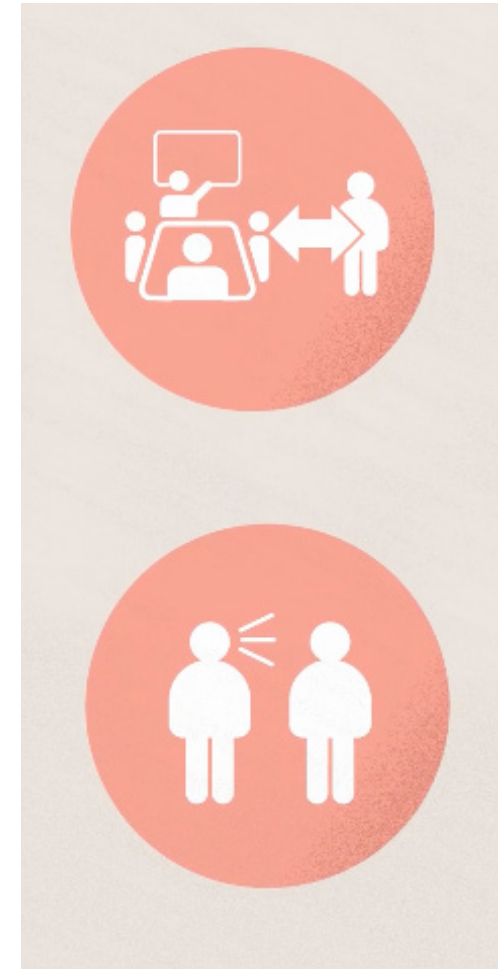


Harassment Behaviour

Behaviour is also considered to be harassment when an employee is treated less favourably because they have previously rejected – or submitted to – unwanted conduct of a sexual nature.

Also covered is any unfavourable treatment related to gender reassignment or sex.

Harassment can be subtle – for example, regularly excluding a team member from meetings. Or it may be obvious and undisguised, like intimidating or threatening behaviour.

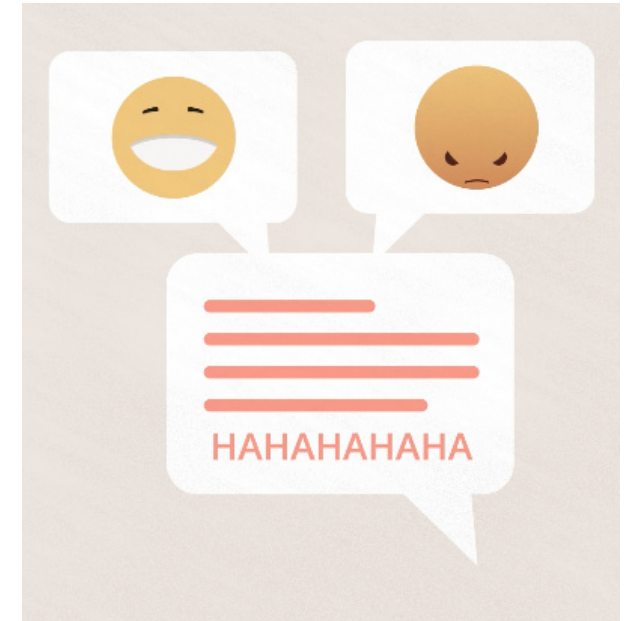




Insignificance of Intent

Importantly, the intent behind the behaviour isn't significant in the eyes of the law. In other words, it may be harassment even if the individual concerned didn't mean to offend or intimidate.

What one person might see as so-called 'banter' or joking, another might find offensive.



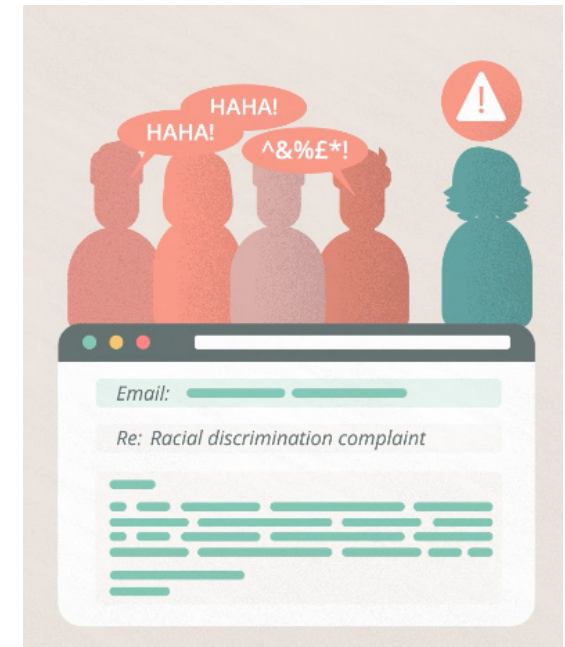


Victimisation

Victimisation, on the other hand, is defined by the Equality Act as treating someone detrimentally because they've carried out a 'protected act'.

This phrase refers to making a discrimination complaint, or a legal claim under the Equality Act. It also covers supporting a colleague who has done so.

For instance, imagine an employee makes a complaint after their manager continually makes racist jokes in their presence, despite being asked not to. Afterwards, the person who raised the complaint is excluded from senior team meetings, and unfairly denied a promotion. This could amount to victimisation.





Tackling Harassment and Victimisation

In 2020, the Equality and Human Rights Commission published technical guidelines to help UK employers and managers tackle harassment and victimisation at work.

They recommend establishing systems to monitor warning signs, as well as making it easier for employees to report harassment and victimisation – anonymously, if they prefer.

These policies, processes and procedures must be communicated to every employee, and staff should be trained on how to address all forms of harassment and victimisation, from the point of hire onwards.



Handling Harassment and Victimisation Complaints

Discrimination, harassment and victimisation don't only prevent the creation of an equal, inclusive and diverse culture – as we've mentioned, they are also prohibited under law. Left unaddressed, these behaviours can have a serious impact, both on the individual workers affected and the entire organisation.

Therefore, it's in the best interests of the company and its managers to develop systems to prevent such problems occurring. And if they do, they should be handled promptly and appropriately. Find out more by downloading this lesson's associated information sheet.





Keeping Up to Date with Legislation

All the laws and regulations that we've looked at are important for every manager to understand to keep people protected and safe – and they relate to both the workplace and society in general.

The 'legislation.gov.uk' website is the official repository for UK legislation and outlines any changes that have been made to the original Acts.

Although it is not necessary for you to know the details of all relevant acts, being aware of those that impact your daily decision-making will serve you well in your career.





Recap

In this lesson, you have learned about:

- Role of governance in decision-making and long-term sustainability
- How legislation and regulation inform proper operations and conduct
- Compliance as internal controls for adhering to obligations and minimising risks
- Key laws and regulations – data protection, health and safety, and equality and diversity